

1. Types of DoS Attacks

- **Flood Attacks:** Overwhelm the target with excessive traffic or requests to consume bandwidth or resources.
 - Examples: SYN flood, UDP flood, ICMP flood.
 - **Crash Attacks:** Exploit vulnerabilities to crash or freeze the system (e.g., sending malformed packets).
 - **Logic Attacks:** Exploit flaws in applications or protocols (e.g., Ping of Death, Teardrop).
 - **Amplification Attacks:** Use third-party systems to multiply the attack traffic (e.g., DNS amplification).
-

2. How DDoS Attacks Work

- A **DDoS attack** uses multiple compromised machines (bots) distributed worldwide to flood a target simultaneously.
- Attackers build **botnets** by infecting computers with malware that connects them to a command and control (C&C) server.
- The attacker commands the botnet to send traffic or requests to the victim, overwhelming resources.
- The distributed nature makes detection and mitigation harder.

3. How BOTs/BOTNETs Work

- **Bots:** Malware-infected computers controlled remotely by an attacker.
- **Botnets:** Networks of bots controlled by a C&C infrastructure.
- Botnets perform coordinated attacks, send spam, steal information, or mine cryptocurrencies.
- Command and control can use various communication protocols like IRC, HTTP, or peer-to-peer.

4. Smurf Attacks

- A **Smurf attack** is a type of ICMP flood.
 - The attacker sends ICMP echo requests to a broadcast address with the victim's IP spoofed as the source.
 - All devices on the network reply to the victim, amplifying the traffic and overwhelming it.
 - Prevented by disabling IP-directed broadcasts on routers.
-

5. SYN Flooding

- Exploits the TCP 3-way handshake.
 - The attacker sends a large number of SYN requests but never completes the handshake.
 - The victim allocates resources for each half-open connection, leading to resource exhaustion.
 - Countermeasures include SYN cookies and limiting half-open connections.
-

6. Spoofing vs Hijacking

- **Spoofing:** Pretending to be another device by falsifying data like IP or MAC addresses.
 - **Hijacking:** Taking over an existing session or connection by stealing session tokens or credentials.
-

7. Types of Session Hijacking

- **Active Hijacking:** Attacker takes over the session and sends packets to the server.
- **Passive Hijacking:** Attacker only listens and captures session data without altering.
- **Man-in-the-Middle (MITM):** Attacker intercepts communication and can alter data.

- **Cross-site scripting (XSS):** Used to steal session cookies.
-

8. Steps to Perform Session Hijacking

1.
Session Identification: Discover valid session IDs or tokens.
 2.
Session Prediction: Guess or brute force session tokens.
 3.
Session Fixation: Attacker sets a known session ID and tricks victim into using it.
 4.
Session Sniffing: Capture session tokens via sniffing.
 5.
Session Injection: Insert malicious packets into session.
-

9. Prevention of Session Hijacking

- Use **encrypted connections (HTTPS)** to protect session data.
- Implement **session timeouts** and **re-authentication**.
- Use **secure, random, and long session IDs**.
- Employ **HTTPOnly** and **Secure flags** on cookies.

- Use **IP address and user-agent verification** during session.
- Employ **Intrusion Detection Systems (IDS)** to detect anomalies.